

INFORMATION SECURITY POLICY

Tumaini Capital Ltd | ISMS-POL-001 | ISO/IEC 27001:2022 — Clause 5.2 | Fictional case study

Document Title	Information Security Policy	Document ID	ISMS-POL-001
Version	1.1	Status	<i>DRAFT — Pending CEO Approval</i>
Author	Head of Risk & Compliance	Date	June 2026
Approved By	Chief Executive Officer	Next Review	June 2027
Related Documents	ISMS-DOC-001 (Scope Statement), ISMS-DOC-006 (Risk Assessment), ISMS-REG-001 (Document Register)		

1. PURPOSE

This Information Security Policy establishes Tumaini Capital Ltd.'s commitment to protecting the confidentiality, integrity, and availability of its information assets. It provides the overarching framework within which the Information Security Management System (ISMS) operates, and from which all supporting policies, procedures, and controls are derived.

This policy applies to all staff, contractors, third parties, and systems that create, process, store, or transmit Tumaini Capital's information within the defined ISMS scope.

2. SCOPE

This policy applies to the digital lending platform (mobile application and USSD channel), the core lending engine and its supporting AWS infrastructure, the Customer Relationship Management (CRM) system, and all customer and borrower data processed therein, including KYC documentation. The scope covers the Nairobi (Upper Hill) headquarters, the Kisumu office, and information accessed via personally-owned devices used for business purposes.

The full scope is defined in the ISMS Scope Statement (ISMS-DOC-001).

3. INFORMATION SECURITY OBJECTIVES

Tumaini Capital has established the following information security objectives, which this policy exists to support:

- Achieve ISO/IEC 27001:2022 certification within 12 months, fulfilling the regional bank white-label partnership due-diligence requirement.
- Reduce unauthorized access incidents to zero by implementing formal access control and offboarding procedures, with all leaver accounts deactivated within 24 hours of exit.
- Demonstrate continuous compliance with the Data Protection Act, 2019 and maintain zero major nonconformities in the first internal audit cycle.
- Maintain availability of the core lending platform at 99.5% uptime or better.
- Achieve at least 90% completion of security awareness training across all staff within the first six months of the ISMS going live.

4. INFORMATION SECURITY PRINCIPLES

4.1 Confidentiality

Information shall be accessible only to those with a legitimate, documented business need. Access shall be granted on a least-privilege basis and reviewed regularly. Customer and borrower data, including KYC documentation, shall be treated as Restricted and protected accordingly.

4.2 Integrity

Information shall be accurate, complete, and protected against unauthorized modification. Controls shall be in place to detect and prevent unauthorized alteration of customer records, loan data, and financial transactions.

4.3 Availability

Information and information systems shall be available to authorized users when needed. Business continuity arrangements shall be maintained for critical systems, with defined recovery time and recovery point objectives.

4.4 Risk-based approach

Information security controls shall be proportionate to the risks they address. Tumaini Capital shall maintain a formal risk assessment and treatment process and shall select controls that reduce risks to acceptable levels within defined risk acceptance criteria.

4.5 Legal and regulatory compliance

Compliance with the Data Protection Act, 2019; the Computer Misuse and Cybercrimes Act, 2018; Central Bank of Kenya digital lending guidance; and all applicable contractual obligations is mandatory. No information security objective or business priority shall override a legal compliance obligation.

4.6 Shared responsibility

All Tumaini Capital staff are responsible for information security within their roles. Security is not solely the responsibility of the IT or Risk & Compliance functions. Every member of staff who handles company information contributes to the organization's security posture.

5. POLICY FRAMEWORK

This Information Security Policy is supported by a suite of policies, procedures, and plans that together form the ISMS policy framework. All supporting documents are subordinate to this policy and must be consistent with it.

The current list of active ISMS supporting documents is maintained in the ISMS Document Register (ISMS-REG-001), which serves as the single authoritative reference for the policy framework at any point in time. New supporting documents may be added to the framework to address emerging risks, regulatory requirements, or operational needs, provided they are approved through the ISMS document control process and entered into the Document Register.

All supporting documents are reviewed at least annually and following any material change to the business, technology landscape, or regulatory environment.

6. ROLES AND RESPONSIBILITIES

- The Chief Executive Officer is responsible for approving this policy, providing visible leadership and commitment to information security, and ensuring adequate resources are allocated to the ISMS.
- The ISMS Lead (Head of Risk & Compliance) is responsible for implementing and maintaining the ISMS, managing the policy framework, conducting risk assessments, and reporting to the CEO on ISMS performance.
- The Head of Engineering is responsible for implementing and maintaining technical security controls across the AWS infrastructure, CRM, lending platform, and endpoint estate.

- All staff are responsible for complying with this policy and all supporting policies, reporting information security events promptly, completing mandatory security awareness training, and safeguarding the information they have access to.
- Third-party suppliers with access to Tumaini Capital's information or systems are required to comply with applicable information security requirements as specified in their contracts.

7. COMPLIANCE AND CONSEQUENCES

Compliance with this policy and all supporting ISMS documents is mandatory for all persons within scope. Failure to comply may result in disciplinary action up to and including termination of employment or contract, depending on the severity of the violation. Breaches that result in a legal or regulatory violation may also be referred to the relevant authorities.

8. REVIEW AND MAINTENANCE

This policy shall be reviewed annually by the ISMS Lead, approved by the CEO, and communicated to all staff. Reviews shall also be triggered by a material change to the business or technology landscape, a significant security incident, a change in applicable legal or regulatory requirements, or a recommendation from an internal or external audit.

9. MANAGEMENT COMMITMENT

By approving this policy, the Chief Executive Officer confirms Tumaini Capital's commitment to establishing, implementing, maintaining, and continually improving the Information Security Management System in accordance with ISO/IEC 27001:2022.

Role	Name & Signature	Date
Chief Executive Officer (Approver)		
Head of Risk & Compliance (ISMS Lead)		